

# CRAFT Configuration and Validation

## *Certificate Request Agent for Tickets | Administrator reference*

Configure one of three Linux operating modes: privileged certificate enrollment through CES and AD CS, privileged credential linking through msDS-KeyCredentialLink, or unprivileged PKINIT with a certificate exported from Windows. This guide compares their requirements and gives mode-specific configuration and acceptance checks. The linked source guide contains the complete installation commands.

| Requirement                  | 1 Enrollment                             | 2 Credential linking                           | 3 Windows export                                       |
|------------------------------|------------------------------------------|------------------------------------------------|--------------------------------------------------------|
| Linux acquisition            | Setuid launcher; craft service account   | Setuid launcher; craft service account         | Caller UID; mode-0755 executables                      |
| User credential              | CA-enrolled short-lived certificate      | Temporary linked public key and local identity | Transferred certificate and private-key PEM pair       |
| Service keytab / LDAP        | Required                                 | Required                                       | Unused                                                 |
| CES / agent / user template  | Required                                 | Unused                                         | Direct Windows enrollment template; no Linux CES/agent |
| Authorization                | CA agent/template/recipient restrictions | Scoped AD attribute delegation                 | User enrollment and KDC certificate mapping            |
| KDC certificate trust / CRLs | Required                                 | Required                                       | Required                                               |
| Setup                        | <a href="#">Mode 1 instructions</a>      | <a href="#">Mode 2 instructions</a>            | <a href="#">Mode 3 instructions</a>                    |

## Shared Linux preparation

Build from the repository root using a C++20 compiler and standard library with std::format, CMake and the OpenSSL 3, MIT Kerberos, libcurl, libxml2, OpenLDAP and SASL dependencies. MIT PKINIT is required at runtime; modes 1 and 2 also require the SASL GSSAPI plugin. Use patched distribution packages and the exact requirements in the source guide.

```
cmake -S source -B build -DCMAKE_BUILD_TYPE=Release
cmake --build build -j2
ctest --test-dir build --output-on-failure
```

Install the trusted launcher, worker and optional maintainer. Keep /etc/craft/config and krb5.conf root-owned mode 0644 with protected parents. Pin the realm, KDC and expected KDC hostname; provide populated kdc-trust.pem and current kdc-crls.pem. Modes 1 and 3 also require ca-trust.pem and ca-crls.pem for the user certificate; enrollment also validates the agent. Empty placeholders are invalid. Refresh CRLs independently.

Modes 1 and 2 add craft:craft, craft-users and /run/craft owned craft:craft mode 0700. Private service credentials are root:craft mode 0640. Only the service account belongs to craft; ordinary users join craft-users. Keep enabled=no and the launcher non-setuid until the selected setup is ready, then enable acquisition and set launcher mode 4750. Users invoke craft directly without sudo.

[Shared installation](#) | [Privileged installation](#) | [Three-mode process guide](#)

## Mode 1 privileged certificate enrollment setup

[Complete mode 1 setup](#) | [Enrollment flow diagram](#) | [CA authorization](#)

Complete the shared Linux and privileged installation. Provision a directory/submission account with AES keys and install submitter.keytab. Install the enrollment-agent certificate and matching unencrypted key as agent.pem and agent.key. Install CES HTTPS trust as https-trust.pem. Protect these files as root:craft mode 0640.

Configure AD CS and CES for initial enrollment using a dedicated EOBO user template. Restrict the actual signing agent, permitted template and approved recipient group at the CA; exclude privileged identities. Resolve Linux names to the intended AD sAMAccountName and directory UPN. CA-built identity and SID mapping must satisfy current KDC policy. The CA helper performs partial lab provisioning and does not replace these checks.

```
enabled=no
domain=domain.local
realm=DOMAIN.LOCAL
mechanism=enrollment
netbios=DOMAIN
service_principal=svc-linux-enroll@DOMAIN.LOCAL
template_oid=1.3.6.1.4.1.311.21.8.999.1
ces_url=https://ces.domain.local/IssuingCA_CES_Kerberos/service.svc/CES
ces_auth=negotiate
certificate_cn={user}
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
cert_remaining_max_seconds=36000
cert_total_max_seconds=36000
minimum_interval_seconds=60
```

Replace every placeholder. template\_oid is the actual msPKI-Cert-Template-OID, not the template display name. The CES URL is pinned, not discovered through Windows enrollment policy. Configure the optional GC endpoint/base when needed. The helper signs DOMAIN\user in the EOBO request and validates the returned certificate against the directory UPN.

| CES transport | Additional requirements                                                                                                                                                                        |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| negotiate     | Service keytab authenticates HTTP as well as LDAP. Configure the HTTP SPN and required CES-to-CA constrained delegation. The worker's short-lived transport TGT is never returned to the user. |
| mtls          | Use the actual certificate-authenticated CES endpoint and separate https-client.pem / https-client.key mapped to the submitting account. The directory keytab is still required.               |

Validate the template profile on the next page and prove CA refusal for out-of-scope recipients. Set enabled=yes and enable the setuid launcher only when ready. Test as an approved user with both home PEM files absent, so the supplied-certificate path does not hide the enrollment setup.

## Mode 1 certificate and ticket policy

The CA controls the issued certificate. CSR extensions are requests, and client-side validation cannot replace CA authorization. This profile applies to CRAFT enrollment; mode 3 accepts its separate supplied-certificate profile and mode 2 is authorized by its directory key.

| Property                  | Required enrollment profile                                                                                                                                                                                                  |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Subject and identity      | The UPN otherName SAN (1.3.6.1.4.1.311.20.2.3) must match the directory-resolved UPN. The CA supplies the account SID security extension for current AD certificate mapping. The CN is not the authentication identity.      |
| Client EKUs               | Client Authentication 1.3.6.1.5.5.7.3.2<br>Smart Card Logon 1.3.6.1.4.1.311.20.2.2<br>PKINIT Client Authentication 1.3.6.1.5.2.3.4                                                                                           |
| Key and basic constraints | CRAFT generates RSA-3072. Explicit CA:FALSE with no path length; digitalSignature required; keyCertSign and cRLSign forbidden. The CSR also requests keyEncipherment.                                                        |
| Template                  | Template-information extension must contain the configured template OID. The signing agent must be authorized for that template and recipient.                                                                               |
| Validity                  | Current validity with more than 60 seconds remaining. Default cap is ten hours total notBefore-to-notAfter, including backdating, and ten hours remaining. The client refuses excessive validity rather than changing dates. |
| Trust and revocation      | Matching private key, configured CA chain and current CRLs for the user certificate and enrollment agent. KDC certificate trust and revocation are checked separately.                                                       |
| Agent profile             | Certificate Request Agent ECU 1.3.6.1.4.1.311.20.2.1, matching private key, trusted chain and current CRLs. Scope comes from CA restrictions, not that ECU.                                                                  |

## Shared ticket policy

tgt\_seconds=36000 and renew\_seconds=604800 request ten-hour initial validity and seven-day renewal in every mode. The KDC decides the actual grant, including certificate/key-lifetime constraints. Strict require\_full\_tgt\_lifetime=yes rejects shortened grants and preserves the cache; no accepts them with a warning. CRAFT never rewrites issued ticket times. AES256/AES128 are required for both session keys and outer ticket encryption.

## Generated common name

certificate\_cn={user} controls the mode 1 CSR CN and mode 2 local-certificate CN. Tokens are {user}, directory-resolved {upn} and {domain}; the result must be 1-64 printable ASCII characters. A CA-built subject can override the CSR. The setting does not alter mode 3's supplied certificate or the requested principal. Preserve UPN/SID binding and recipient restrictions when configuring CA subject policy.

[Windows enrollment preparation](#) | [Configuration example](#)

## Mode 2 privileged credential linking setup

[Complete mode 2 setup](#) | [Credential-linking diagram](#) | [Directory delegation](#)

Complete shared Linux and privileged installation. Provision the service principal with AES keys and install submitter.keytab as root:craft mode 0640. Use a schema exposing msDS-KeyCredentialLink and a writable KDC supporting NGC/Key Trust, as provided by Windows Server 2016 or later. A domain-functional-level label alone does not establish these capabilities. The KDC still needs a trusted PKINIT certificate and current CRLs.

Pin the same writable DC in krb5.conf and kt\_dc\_url so its KDC sees the new key immediately. The LDAP SASL/GSSAPI bind must provide integrity and confidentiality. For Key Trust alone, remove the optional pkinit\_pool reference to user-certificate ca-trust.pem if unnecessary, or point it at a root-controlled bundle of KDC intermediates; retain KDC anchors and CRL checking.

```
enabled=no
domain=domain.local
realm=DOMAIN.LOCAL
mechanism=key_trust
service_principal=svc-linux-enroll@DOMAIN.LOCAL
kt_dc_url=ldap://dc01.domain.local
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
minimum_interval_seconds=60
```

Delegate ReadProperty/WriteProperty on only msDS-KeyCredentialLink over a reviewed OU of ordinary users or a single user. The service account can authenticate as every target in that scope. Keep privileged identities out, protect the OU membership/ACL administrators, and prevent the service account from rewriting its delegation. Preview the helper rule before applying it:

```
.\scripts\Grant-CRAFTKeyCredentialLink.ps1 -ServiceAccount svc-linux-enroll `
-TargetOU "OU=CRAFT Users,DC=domain,DC=local" -WhatIf
```

CRAFT generates a fresh RSA-2048 key and locally issued certificate identity. The linked public key authorizes PKINIT, without user-certificate CA enrollment, CES, an agent or a template. MIT Kerberos handles PKINIT negotiation, including freshness tokens; validate against the actual KDC policy.

An independent process adds and removes CRAFT's exact value while preserving existing keys. Successful acquisition requires removal before cache publication. Cleanup also runs after acquisition failure or worker termination and retries uncertain directory outcomes. A continuing directory outage or host failure can leave a usable key. Failed cleanup blocks publication and reports a CRITICAL AUTHPRIV event when cleanup runs; remove residual credentials manually.

Review delegation and trust, set enabled=yes, and enable the setuid launcher. Test with both home PEM files absent. Verify the returned caller principal, attribute cleanup, existing-key preservation and directory refusal for out-of-scope accounts; repeat after revoking the delegation.

## Mode 3 unprivileged Windows exported certificate setup

[Complete mode 3 setup](#) | [Windows export flow diagram](#) | [Windows helper details](#)

Complete shared Linux installation with ordinary mode-0755 executables. No setuid bit, service account, caller group, service keytab, LDAP lookup, CES or /run/craft is needed for Linux acquisition. Host installation and public Kerberos/trust provisioning remain administrator tasks.

On Windows, run the helper as the intended signed-in domain user without elevation. Choose the template's internal name or OID, with direct user enrollment, exportable software keys and a KDC-accepted identity/profile. Windows PowerShell and its PKI module use AD enrollment policy to select an eligible CA. No OpenSSL or enrollment-agent credential is required.

```
.\scripts\Request-CRAFT-Certificate.cmd UserLogon "C:\Users\Alice\CRAFT Certificate"
```

Securely transfer both exported user.pem and matching unencrypted PKCS#8 user.key to Linux after the helper returns successfully. Keep its private tracking metadata on Windows. As the intended Linux user, install the pair in the NSS-resolved home; HOME and XDG overrides do not change that location:

```
mkdir -p ~/.config/craft
chmod 0700 ~/.config/craft
install -m 0600 /path/to/transferred/user.pem ~/.config/craft/user.pem
install -m 0600 /path/to/transferred/user.key ~/.config/craft/user.key
```

Both files must be caller-owned regular files, nonempty, at most 1 MiB and have one hard link. Symlinks are refused. The key must be unencrypted with no group/other permissions; the certificate must not be group/world-writable. The home, .config and craft directories must be caller-owned and not group/world-writable. Direct PFX loading, passphrase prompts, PKCS#11 and hardware-key backends are unsupported.

```
enabled=no
domain=domain.local
realm=DOMAIN.LOCAL
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
```

Provide root-owned mode-0644 CA and KDC trust bundles with current CRLs. The user certificate must match the key; have explicit CA:FALSE without a path length, digitalSignature without certificate/CRL signing, Smart Card Logon or PKINIT Client Authentication EKU, exactly one well-formed UPN SAN, and current validity. The KDC must map it to <Linux username>@<realm>. CRAFT does not query the directory UPN or pin the enrollment template/ten-hour certificate cap in this mode.

Set enabled=yes when ready. There is no mechanism=home setting: the complete PEM pair selects this path, including on privileged installations. Partial or invalid pairs fail without fallback. Repeat the Windows helper to check renewal and transfer replacements before expiry. Its default window is one calendar month; /RenewBeforeDays changes it, and /DeleteAfterExport optionally removes the Windows-store certificate. Neither the helper nor CRAFT schedules or transfers replacements automatically.

## Acceptance checks and ongoing operation

Run the offline checks, then validate the chosen installed mode against disposable identities in an isolated AD lab. Offline fixtures or a successful MIT KDC trial do not establish AD certificate mapping, CES interoperability, the directory delegation or the installed setuid boundary.

| Scope                 | Required observations                                                                                                                                                                                                                                                                                                   |
|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Every mode            | Run as the intended non-root user without sudo. Confirm Linux-name principal, caller-owned mode-0600 cache, renewable/nonforwardable/nonproxiabable flags, AES session/ticket encryption and actual lifetimes. Test a real Kerberos-enabled service.                                                                    |
| Selection and failure | The complete home pair takes priority. Partial/unsafe/invalid files must preserve the cache without either privileged mechanism. With both absent, use only the configured mechanism. Test wrong mapping, stale required CRLs, key mismatch, KDC outage, RC4 and shortened strict-mode grants.                          |
| 1 Enrollment          | Inspect UPN, CA SID mapping, template, three EKUs, matching key, CN behavior, chain/CRLs and total validity. Prove CA denial for unauthorized agents/templates/recipients and correlate CA/CES audit identity.                                                                                                          |
| 2 Credential linking  | Prove scoped attribute rights and denial outside the scope. Inspect the added/removed value and existing keys before and after success, failed PKINIT and interruption. Force cleanup failure, verify refusal to publish and remove the residual key. Test revocation of delegation and KDC freshness interoperability. |
| 3 Windows export      | Verify ordinary Linux execution without service credentials or runtime directory, safe Windows PEM export/transfer, KDC mapping, certificate replacement and inherited no_new_privs. Wrong-account and unsafe/partial pairs must preserve the cache.                                                                    |

```
cache=$(/usr/local/bin/craft) || exit "$?"
export KRB5CCNAME="$cache"
klist -ef -c "$KRB5CCNAME"
```

### Long running jobs

```
job_pid=$$
cache=$(/usr/local/bin/craft-maintain --watch-pid "$job_pid") || exit "$?"
export KRB5CCNAME="$cache"
```

The ordinary maintainer needs Linux 5.3+, /proc and system /etc/krb5.conf matching the pinned realm/KDC and AES policy. The scheduler must retain detached processes. Renewal uses the cache alone; fresh authentication applies the same three-mode selection. Keep CRLs, service credentials and supplied certificates current. Status/log failures preserve the cache and retry; later failures do not terminate the job.

Test renewal, fresh authentication near the absolute renewal deadline, outages, concurrent jobs and termination with the watched PID under the actual scheduler. Applications must reload refreshed credentials. Cache files remain after exit, and certificate expiry or directory-key removal does not revoke already-issued tickets.

[Full acceptance cases](#) | [Maintenance setup and status](#)

Source code, scripts, configuration examples and documentation are licensed under GNU GPL version 3 only (GPL-3.0-only). See [LICENSE](#) for the terms and warranty disclaimer.